

GSG-01

SMB Security Guide

Plain-Language Security for Small Business

This guide provides small and medium businesses with a plain-language foundation in cybersecurity — covering the threat landscape, key control areas, and practical first steps. No technical background required.

// INTRODUCTION

Why Security Matters for Small Business

Cybercriminals do not just target large corporations. In fact, small and medium businesses are among the most frequently targeted organizations — precisely because they are seen as having valuable data and weaker defenses than enterprise-scale competitors. A single incident — ransomware, a data breach, or a successful phishing attack — can cost a small business tens of thousands of dollars in recovery costs, legal fees, and lost revenue, in addition to the reputational damage that is often impossible to fully recover from.

This guide is designed to give you a clear, jargon-free foundation in the areas that matter most. You do not need a technical background to benefit from it. Work through it at your own pace, and use it alongside the Green Security Group Security Assessment to identify and prioritize the gaps specific to your business.

01 The Threat Landscape

// WHAT YOU'RE UP AGAINST

Understanding the types of threats targeting small businesses is the first step to defending against them. The following are the most common — and most impactful — threats faced by SMBs today.

Phishing and Social Engineering

Phishing emails trick employees into revealing credentials, clicking malicious links, or initiating unauthorized wire transfers. Modern phishing is highly targeted — attackers research your business, your staff names, and your vendors to craft convincing messages. Business Email Compromise (BEC), where attackers impersonate executives or vendors to request fraudulent payments, costs small businesses billions of dollars annually.

Ransomware

Ransomware encrypts your files and demands payment for the decryption key. Small businesses are increasingly targeted because they are less likely to have robust backups or incident response capabilities. Recovery without paying the ransom requires complete, tested backups — something many SMBs lack.

Credential Theft

Stolen usernames and passwords — purchased from data breach dumps or harvested via phishing — are used to access cloud services, email accounts, and business systems. Without multi-factor authentication, a single compromised password can provide an attacker complete access to your email, files, and financial accounts.

Insider Threats

Not all threats are external. Disgruntled employees, contractors with excessive access, or simply careless staff can cause significant damage — intentionally or accidentally. Proper access controls, offboarding processes, and monitoring are key mitigations.

Supply Chain and Vendor Compromise

Attackers increasingly target software vendors, managed service providers, and other third parties to gain access to their customers. If your IT vendor or a SaaS tool you use is compromised, your data may be at risk even if your own systems are secure.

02 The 8 Core Security Control Domains

// YOUR SECURITY FRAMEWORK

Effective security is not a single tool or a one-time project. It is a set of ongoing practices across multiple areas of your business. The Green Security Group Assessment organizes these into eight domains — each representing a distinct area of risk and a set of controls that reduce that risk.

Domain 01 — Physical Security

Controls that restrict unauthorized physical access to your equipment, facilities, and sensitive documents. Often overlooked by small businesses, physical access is frequently the simplest path to a serious breach.

Domain 02 — Access Controls

Who can access what — and why. The principle of least privilege, multi-factor authentication, account lifecycle management, and password policy are the foundation of access control.

Domain 03 — Network Defenses

Your firewall, network segmentation, patch management, remote access controls, and endpoint protection. Network defenses limit how far an attacker can move once inside your environment.

Domain 04 — Data Protection

Identifying, classifying, encrypting, backing up, and properly disposing of sensitive data. You cannot protect data you do not know you have.

Domain 05 — Incident Response

Your plan for what to do when something goes wrong — detection, containment, communication, recovery, and post-incident review. Organizations with a plan recover faster and spend less.

Domain 06 — Vendor and Third-Party Risk

The security practices of your vendors, contractors, and SaaS tools are an extension of your own risk. Vendor risk management ensures those relationships do not become liabilities.

Domain 07 — Security Awareness

Your employees are both your greatest vulnerability and your best defense. Security awareness training, phishing simulations, and clear reporting processes turn staff into a human firewall.

Domain 08 — Cloud and Remote Work

Cloud services, remote access, BYOD devices, and distributed work introduce new risks that require updated controls beyond what worked in a purely office-centric environment.

03

Quick Wins — High Impact, Low Effort

// WHERE TO START

If you are new to security or working with limited resources, the following controls provide the highest return on investment. They are not technically complex, they are available to any business regardless of size, and they address the most common causes of small business incidents.

1. Enable Multi-Factor Authentication (MFA) on Everything

MFA prevents the vast majority of credential-based attacks. Enable it on your email platform, cloud storage, banking, and any other system accessible from the internet. Microsoft Authenticator or Google Authenticator are free. This single control is the highest-impact action most small businesses can take immediately.

2. Deploy a Business Password Manager

Reused, weak, or shared passwords are one of the leading causes of breaches. A business password manager (Bitwarden Teams or 1Password Business) ensures every account has a unique, strong password without requiring staff to memorize them. Cost: approximately \$3-5 per user per month.

3. Back Up Your Data — and Test It

Implement the 3-2-1 rule: three copies of data, on two different media types, with one copy offsite or in cloud storage. Critically, test your restoration process at least quarterly. A backup you have never tested is not a backup.

4. Keep Everything Patched

Unpatched software is one of the most common attack vectors. Enable automatic updates for operating systems and applications. Create a process for patching network devices — routers, switches, and access points — quarterly. Critical security patches should be applied within 14 days of release.

5. Train Your Staff

Run a security awareness session at least annually. Cover phishing recognition, how to report suspicious emails, and your password policy. New employees should receive training within their first 30 days. This does not need to be expensive — CISA and KnowBe4 offer free training resources.

04

Building a Security Program

// BEYOND QUICK WINS

Once your quick wins are in place, the goal is to build a sustainable, ongoing security program — not a one-time project. The following practices define a basic but effective security program for a small business.

Document Your Policies

Written security policies create accountability and set clear expectations for staff. At minimum, every small business should have an Acceptable Use Policy (AUP) defining what business systems may be used for, a Password Policy specifying minimum requirements, and an Incident Response Plan outlining what to do when something goes wrong. The Green Security Group Toolkit includes templates for all three.

Know Your Assets

You cannot protect what you do not know you have. Maintain a simple inventory of all business devices, cloud services, and software. Review it quarterly. Flag anything that is no longer in use for decommissioning.

Manage Vendor Access

Every vendor or contractor with access to your systems or data represents risk. Maintain a list of all third-party access, review it quarterly, and revoke access immediately when a relationship ends. Before onboarding a new vendor with data access, ask for their security documentation.

Review and Improve

Security is not a one-time project. Schedule an annual review: repeat the security assessment, review your policies, test your backups, and run a tabletop exercise to walk through your incident response plan. Use the results to update your

priorities for the coming year.

05**When Something Goes Wrong**

// INCIDENT RESPONSE BASICS

Despite your best efforts, incidents will happen. Having a documented, practiced response plan is the difference between a contained incident and a business-threatening crisis.

The Four Phases of Incident Response**Identification**

Recognize that something is wrong. Indicators include unusual system behavior, unexpected account lockouts, reports from staff of suspicious emails, or alerts from your security tools.

Containment

Limit the damage. Isolate affected systems from the network, revoke compromised credentials, and prevent the incident from spreading. Do not power off affected systems without professional guidance — this may destroy forensic evidence.

Recovery

Restore normal operations. Rebuild affected systems from clean backups, reset credentials, and verify that the threat has been removed before bringing systems back online.

Post-Incident Review

After recovery, document what happened, how it was detected, how it was contained, and what could be improved. Update your incident response plan with lessons learned.

Who to Call

Prepare a contact list before an incident occurs. Include: your IT vendor or MSP, your cyber liability insurance provider's claims hotline, a trusted legal advisor familiar with data privacy law, and the Canadian Centre for Cyber Security (cyber.gc.ca) or equivalent national authority. Post this list in your server room and share it with key staff.

06**Recommended Resources**

// WHERE TO GO NEXT

The following free resources can help you build on the foundation established in this guide.

Green Security Group — greensecuritygroup.com

Complete the free SMB Security Assessment to get a scored report across all eight control domains, then download the Security Toolkit for ready-to-use policy templates, a risk register, and a 90-day remediation roadmap.

Canadian Centre for Cyber Security — cyber.gc.ca

Canada's national authority for cybersecurity guidance. The CCCS publishes practical guidance for small businesses including baseline security controls, ransomware response guidance, and alerts on active threats.

CISA Small Business Resources — cisa.gov/resources-tools/resources/small-business

The U.S. Cybersecurity and Infrastructure Security Agency publishes free cybersecurity resources specifically for small businesses, including training materials, toolkits, and assessment guides.

NIST Cybersecurity Framework — nist.gov/cyberframework

The industry-standard framework for organizing security programs. The CSF 2.0 Tiers and Profiles can help you assess your current maturity and set improvement targets.

Have I Been Pwned — haveibeenpwned.com

Enter your business email domain to check whether any employee credentials have appeared in known data breaches. Free for individual email addresses; enterprise monitoring available for organizations.

// AI DISCLOSURE

This document was developed with assistance from Claude (Anthropic), a large language model. All content has been reviewed and validated by Paul Green, CISSP. AI accelerated the writing process; it did not substitute for the practitioner expertise behind it.